

ISO 27001:2022 ↔ NIST CSF Mapping

Strategic Compliance Report | grc-risk-assessment-fintech

1. Executive Summary

This report details the alignment of 93 security controls from ISO 27001:2022 into the NIST Cybersecurity Framework functions. This mapping ensures technical security is balanced with organizational governance.

ISO Category	Count	NIST Alignment Focus
Organizational (5.x)	37	Govern & Identify
People (6.x)	8	Protect (Awareness)
Physical (7.x)	14	Protect (Assets)
Technological (8.x)	34	Protect, Detect & Recover

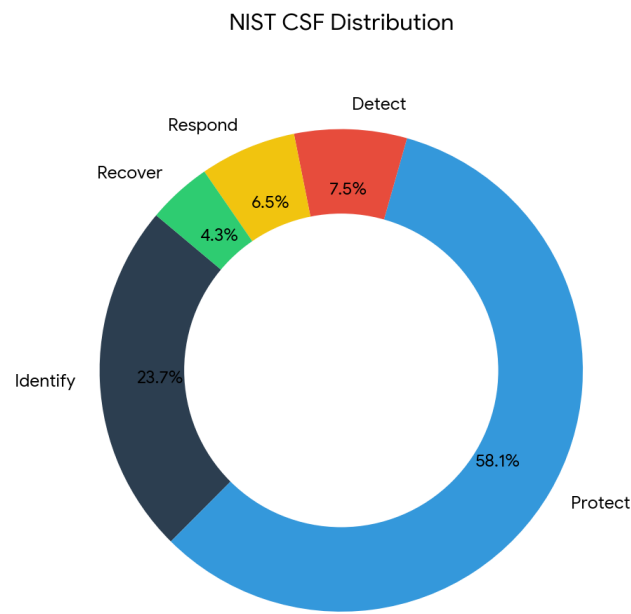


Figure 1: Distribution of controls across NIST Functions.

2. Technical Control Mapping (Abridged)

Detailed mapping of critical technological and organizational controls to NIST sub-categories.

ISO Code	Control Name	NIST Function	Security Objective
5.1	Information Security Policies	Identify (GV)	Governance
5.7	Threat Intelligence	Identify / Detect	Awareness
5.15	Access Control	Protect (AC)	Prevention
5.17	Authentication (MFA)	Protect (AC)	Identity
8.8	Vulnerability Management	Identify / Protect	Hardening
8.12	Data Leakage Prevention (DLP)	Protect (DS)	Exfiltration
8.15	Logging	Detect (AE)	Visibility
8.16	Monitoring Activities	Detect (CM)	Response
8.24	Cryptography	Protect (DS)	Integrity
8.32	Change Management	Identify / Protect	Stability

3. Conclusion

The current framework shows a **strong preventive focus (58.1% Protect)**. To further mature the Fintech GRC posture, it is recommended to continue strengthening the *Detect* and *Respond* capabilities through automated logging and incident playbooks.